SEPARADOR 04 — MONITOREO Y AUDITORÍA

Registro de eventos, trazabilidad y protección de la historia fiscal del sistema KONTROL.

> El sistema lleva un registro de eventos que recopila automáticamente las interacciones, operaciones y sucesos producidos durante su utilización. Todos los registros son rastreables de forma clara y fiable, debidamente fechados y con hora. Este capítulo describe ese registro y demuestra la regla fundamental: **ningún usuario normal, administrador del cliente o usuario de base de datos puede eliminar silenciosamente la historia fiscal**.

1. Modelo de datos del registro de auditoría

KONTROL implementa un registro de eventos de **solo agregar** (*append-only*) en la tabla `audit_events` (módulo `audit`, ADR-012). Cada evento captura, de forma estructurada, todos los campos exigidos por la norma:

Campo del registro	Columna técnica	Exigencia que cubre
Usuario	`user_id`	Usuario que realizó la operación
Fecha	`event_time` (fecha y hora con zona horaria)	Fecha del suceso
Hora	`event_time` (con hora y zona horaria UTC)	Hora del suceso
Operación	`action`	Tipo de operación realizada
Documento involucrado	`entity_type` + `entity_id`	Entidad y documento afectado
Número de documento	`entity_id` / `evidence`	Identificación del documento
Acción realizada	`action` + `reason`	Acción y motivo
Valor anterior	`before` (JSON)	Estado previo del registro
Valor posterior	`after` (JSON)	Estado posterior, cuando procede
Sesión	`session_id`	Sesión de usuario
Origen	`source` + `ip`	Origen del evento (API, etc.) y dirección IP
Evento / resultado	`action` + `evidence`	Resultado y evidencia asociada
Errores / intentos	`action` + `reason`	Errores y motivos de bloqueo
Contexto de negocio	`tenant_id` / `company_id`	Aislamiento y alcance de la empresa
Correlación	`request_id`	Identificador único de la solicitud (X-Request-ID)

2. Eventos registrados automáticamente

2.1 Acceso e identidad

Evento	Descripción
`LOGIN_SUCCESS`	Inicio de sesión correcto
`LOGIN_FAILED`	Intento de inicio de sesión fallido (incluye motivo, p. ej. usuario inactivo)
`LOGIN_BLOCKED`	Bloqueo por umbral de intentos fallidos (5 fallos / 15 minutos)
`SESSION_REFRESHED`	Renovación de sesión
`SESSION_REVOKED`	Cierre de sesión / revocación
`PASSWORD_CHANGED`	Cambio de contraseña
`PASSWORD_RESET_REQUESTED` / `PASSWORD_RESET_CONFIRMED`	Solicitud y confirmación de restablecimiento de contraseña
`USER_CREATED`	Creación de usuario

2.2 Licenciamiento

El módulo de licenciamiento registra en su propio historial inmutable (`license_events`): `LICENSE_IMPORTED` , `LICENSE_SYNCED` , `LICENSE_SYNC_FAILED` , `LICENSE_MODE_CHANGED` , `LICENSE_RENEWAL_REQUESTED` , `LICENSE_RENEWAL_VERIFIED` , `LICENSE_RENEWAL_ISSUED` , `LICENSE_RENEWAL_REJECTED` , `LICENSE_CENTRAL_CONFIGURED` , `LICENSE_SIGNATURE_INVALID` y `LICENSE_INSTALLATION_MISMATCH` .

2.3 Documentos y exportaciones

- La **emisión de documentos fiscales** (facturas, notas de crédito, notas de débito, guías), los **cambios administrativos** y las **anulaciones permitidas** quedan registrados como eventos de auditoría con la entidad y el documento involucrado.
- Toda **exportación de reportes** se registra con el usuario y la acción correspondiente (exportación auditada).
- La línea de tiempo de auditoría está disponible vía `GET /api/v1/reporting/audit/timeline` y el listado filtrable y paginado vía `GET /api/v1/audit/events` (requiere permiso `audit:view`).

2.4 Monitoreo del servicio

- Healthchecks de los contenedores (`/healthz` de la SPA y `/api/v1/health/live` del backend).
- Logs estructurados en JSON (`KONTROL_LOG_JSON=true`) con `request_id` para correlación.
- Identificador de solicitud `X-Request-ID` generado por middleware en cada petición.

3. Regla fundamental: la historia fiscal no se puede eliminar silenciosamente

> **Alteración fiscal**
>
> La Providencia define como alteración fiscal, entre otros supuestos: la **ocultación o eliminación de registros originalmente generados**, la **modificación total o parcial de los datos** y la **incorporación de registros simulados o falsos**. KONTROL adopta controles de diseño, aplicación y base de datos para impedir estas conductas, y para dejar evidencia si cualquier intento ocurriera.

3.1 Controles a nivel de aplicación

- **Registro append-only**: los eventos de auditoría no se modifican ni eliminan por operación normal (`record_audit` solo agrega). No existe funcionalidad de borrado de historia fiscal en la interfaz.
- **Documentos inmutables**: los documentos fiscales emitidos no se reescriben; las correcciones se instrumentan mediante **anulaciones permitidas y notas de crédito/débito**, quedando ambos registros en la historia.
- **Permisos y segregación de funciones (SoD)**: los permisos se asignan por perfil; la auditoría exige permiso específico (`audit:view`) y los procesos sensibles (emisión, anulación, homologación) tienen flujos de aprobación y separación entre quien ejecuta y quien aprueba.
- **Bloqueo de escrituras por licencia**: el middleware de licencia bloquea las operaciones de escritura cuando el modo de acceso es `READ_ONLY` o `SECURITY_SUSPENSION`, impidiendo modificaciones no autorizadas.

3.2 Controles a nivel de base de datos

- **Usuario restringido**: el backend se conecta a PostgreSQL con un usuario de aplicación (no superusuario), configurado mediante `KONTROL_DB_URL`. No se usan credenciales con privilegios administrativos para la operación normal.
- **Sin borrado silencioso**: no existen operaciones de eliminación sobre la historia fiscal en los flujos de negocio; la integridad referencial y las restricciones de la base protegen los registros vinculados.
- **Respaldo y conservación**: los respaldos (`pg_dump`, cifrado AES-256 opcional) preservan la historia fiscal; la restauración es trazable mediante el script `restore.sh`.
- **Trazabilidad**: cualquier cambio en datos administrativos registra `before` / `after`, usuario, sesión, request, fecha y hora, de modo que la modificación total o parcial de datos quedaría documentada.

3.3 Qué queda evidenciado ante un intento de alteración

Supuesto de alteración	Control en KONTROL
Ocultación o eliminación de registros generados	No existe borrado de historia fiscal; registros append-only; usuario de BD sin privilegios de borrado masivo
Modificación total o parcial de datos	Registro de `before` / `after` en auditoría; documentos inmutables; correcciones mediante anulaciones/notas
Incorporación de registros simulados o falsos	Numeración atómica con control de concurrencia; números de control con estado individual; permisos y SoD

4. Consulta y seguimiento

- **Panel de auditoría**: el módulo de auditoría permite consultar los eventos filtrados por entidad, acción y usuario, con fecha/hora y paginación.
- **Línea de tiempo**: el módulo de reportes ofrece una línea de tiempo de auditoría para el seguimiento claro y fiable de las operaciones.
- **Historial de licencia**: eventos de licencia inmutables consultables (`/api/v1/license/history`).
- Todos los registros incluyen **fecha y hora** (con zona horaria) y son rastreables por `request_id` .